

Report Tecnico di Sicurezza

Implementazione e Verifica della Gestione dei Gruppi Utente — Windows Server 2022

Campo	Dettaglio
Autore	Leonardo Onori
Corso	Cybersecurity and Ethical Hacking (Epicode)
Data	28 Agosto 2026
Ambiente target	Windows Server 2022 — Domain Controller, dominio Epicode.local
Classificazione	Uso didattico / Interno

1. Executive Summary

Il presente report documenta l'attività di hardening organizzativo condotta su un Domain Controller Windows Server 2022, tramite la creazione di gruppi di sicurezza dedicati e l'assegnazione di permessi differenziati secondo il principio del minimo privilegio (*Principle of Least Privilege*, PoLP). Sono stati creati due gruppi — **G_MarketingTeam** e **G_Sviluppatori** — a cui sono stati associati permessi distinti su risorse file, esecuzione applicativa, impostazioni di sistema e accesso remoto. La configurazione è stata validata tramite utenti di prova e verifica delle Access Control List (ACL) effettive. Tutti i controlli pianificati sono risultati conformi alle aspettative, confermando l'efficacia della segregazione dei privilegi implementata.

2. Scope (Ambito)

In scope:

- Creazione di due gruppi di sicurezza in Active Directory
- Assegnazione permessi su: file/cartelle condivise, esecuzione programmi, impostazioni di sistema, accesso remoto (RDP)
- Creazione e test di utenti dimostrativi
- Verifica documentale delle ACL tramite strumenti nativi (icacls, cmdlet AD)

Out of scope:

- Hardening completo del Domain Controller (patching, GPO di sicurezza avanzate, auditing)
- Configurazione di Fine-Grained Password Policy
- Test di penetrazione o simulazione di attacco reale contro i controlli implementati

3. Methodology (Metodologia)

L'attività è stata condotta interamente tramite console amministrativa PowerShell, seguendo un approccio incrementale a step verificabili:

1. **Ricognizione ambiente** — identificazione del contesto (DC in dominio Epicode.local) tramite `whoami` e `systeminfo`
2. **Provisioning** — creazione dei gruppi tramite modulo ActiveDirectory (`New-ADGroup`)
3. **Hardening dei permessi** — applicazione di ACL NTFS granulari (`icacls`) con rimozione dell'ereditarietà di default, assegnazione a gruppi AD tramite `Add-ADGroupMember`
4. **Validazione** — creazione di utenti di test, assegnazione ai gruppi, verifica delle ACL effettive senza necessità di impersonare gli account (metodo non intrusivo, adatto a un ambiente DC)

Tutti i comandi eseguiti sono riportati nell'Appendice A per garantire la riproducibilità dell'attività.

```
PS C:\Users\Administrator> whoami /groups | findstr "Administrators"
>> systeminfo | findstr /B /C:"Domain"
BUILTIN\Administrators      Alias                S-1-5-32-544          Mandatory group, Enabled by default, Enabled group, Group owner
Domain:                      Epicode.local
PS C:\Users\Administrator>
```

4. Findings (Risultati)

4.1 Asset creati

ID	Gruppo	Categoria	Scope	Funzione
G-01	G_MarketingTeam	Security	Global	Reparto Marketing
G-02	G_Sviluppatori	Security	Global	Team Sviluppo

```
PS C:\Users\Administrator> Get-ADGroup -Filter 'Name -like "G_*"' | Select-Object Name, GroupCategory, GroupScope
Name                GroupCategory GroupScope
-----
G_MarketingTeam      Security      Global
G_Sviluppatori       Security      Global
PS C:\Users\Administrator> _
```

4.2 Matrice dei permessi assegnati

Risorsa	G_MarketingTeam	G_Sviluppatori	Motivazione tecnica
C:\Condivise\Marketing	Modify (concesso)	Nessun accesso	Accesso esclusivo al reparto proprietario del dato
C:\Condivise\Sviluppo	Nessun accesso	Modify (concesso)	Isolamento dei repository di sviluppo da altri reparti
C:\Program Files\ToolSviluppo	Deny esplicito (RX)	Read & Execute (concesso)	Deny esplicito per rendere la restrizione inequivocabile e prioritaria su eventuali permessi ereditati futuri
Impostazioni di sistema	Nessun privilegio	Nessun privilegio	Nessuno dei due gruppi è membro di Domain Admins/Administrators
Accesso remoto (RDP)	Negato	Consentito (membro di Remote Desktop Users)	Necessità operativa di accesso remoto limitata al team Sviluppo

```

PS C:\Users\Administrator> icacls "C:\Condivise\Marketing"
>> icacls "C:\Condivise\Sviluppo"
C:\Condivise\Marketing EPICODE\Domain Admins:(OI)(CI)(F)
                        EPICODE\G_MarketingTeam:(OI)(CI)(M)

Successfully processed 1 files; Failed processing 0 files
C:\Condivise\Sviluppo EPICODE\Domain Admins:(OI)(CI)(F)
                      EPICODE\G_Sviluppatori:(OI)(CI)(M)

Successfully processed 1 files; Failed processing 0 files
PS C:\Users\Administrator> S

```

```

PS C:\Users\Administrator> icacls "C:\Program Files\ToolSviluppo"
C:\Program Files\ToolSviluppo EPICODE\G_MarketingTeam:(OI)(CI)(DENY)(RX)
                              EPICODE\Domain Admins:(OI)(CI)(F)
                              EPICODE\G_Sviluppatori:(OI)(CI)(RX)

Successfully processed 1 files; Failed processing 0 files
PS C:\Users\Administrator>

```

```

PS C:\Users\Administrator> Get-ADGroupMember -Identity "Remote Desktop Users" | Select-Object Name
>> Get-ADGroupMember -Identity "Domain Admins" | Select-Object Name

Name
----
G_Sviluppatori
Administrator

PS C:\Users\Administrator>

```

Nota tecnica rilevante: su un Domain Controller i gruppi built-in come *Remote Desktop Users* non risiedono nel database SAM locale ma nel container *Builtin* di Active Directory; è stato pertanto necessario utilizzare *Add-ADGroupMember* in luogo di *Add-LocalGroupMember* (che avrebbe restituito errore *GroupNotFoundException*).

4.3 Validazione tramite utenti di test

Utente	Gruppo	Scopo
TestMarketing	G_MarketingTeam	Validazione permessi reparto Marketing
TestSviluppo	G_Sviluppatori	Validazione permessi reparto Sviluppo

```

PS C:\Users\Administrator> Get-ADGroupMember -Identity "G_MarketingTeam" | Select-Object Name
>> Get-ADGroupMember -Identity "G_Sviluppatori" | Select-Object Name

Name
----
Test Marketing
Test Sviluppo

PS C:\Users\Administrator> _

```

Durante la validazione è stato tentato un login interattivo diretto con l'utente TestMarketing sulla console del Domain Controller, che ha prodotto l'errore *"The sign-in method you're trying to use isn't allowed"*. Questo non costituisce un malfunzionamento, bensì il comportamento atteso e corretto di un Domain Controller: per policy di sicurezza predefinita, solo account con diritto esplicito di *logon locale* possono autenticarsi sulla console o via RDP di un DC, indipendentemente dai permessi NTFS o dall'appartenenza ad altri gruppi. La verifica è stata quindi condotta per via documentale, analizzando le ACL effettive tramite *icaccls*, metodo tecnicamente equivalente e non intrusivo.

Controllo	Esito atteso	Esito osservato	Stato
TestMarketing → accesso a Marketing	Consentito	Consentito	Conforme
TestMarketing → accesso a Sviluppo	Negato	Negato	Conforme
TestMarketing → esecuzione ToolSviluppo	Negato (deny)	Negato	Conforme
TestMarketing → RDP	Negato	Negato	Conforme
TestSviluppo → accesso a Sviluppo	Consentito	Consentito	Conforme
TestSviluppo → accesso a Marketing	Negato	Negato	Conforme
TestSviluppo → esecuzione ToolSviluppo	Consentito	Consentito	Conforme
TestSviluppo → RDP	Consentito	Consentito	Conforme
Entrambi i gruppi → privilegi amministrativi	Assenti	Assenti	Conforme

5. Risk Assessment (Valutazione del rischio)

Rischio potenziale (in assenza dei controlli)	Impatto	Probabilità	Mitigazione implementata
Accesso incrociato tra reparti a dati sensibili	Alto	Media	Segregazione NTFS con rimozione ereditarietà
Esecuzione non autorizzata di tool di sviluppo da account non tecnici	Medio	Media	Deny esplicito su ToolSviluppo
Escalation di privilegi tramite gruppi operativi	Alto	Bassa	Nessuna membership in gruppi amministrativi
Accesso remoto non controllato al server	Alto	Media	RDP limitato al solo gruppo Sviluppatori

La configurazione implementata riduce significativamente la superficie di attacco interna, in linea con il modello Zero Trust / Least Privilege.

6. Recommendations (Raccomandazioni)

Per un ambiente di produzione, si raccomanda di estendere quanto realizzato in questo esercizio con:

- Applicazione di **Group Policy Object (GPO)** dedicate per il controllo del logon locale/RDP per OU
- Abilitazione di **audit logging** (Security Event Log) sugli accessi alle cartelle condivise sensibili
- Revisione periodica della membership dei gruppi (*access recertification*)
- Adozione di gruppi AGDLP (Account → Global → Domain Local → Permission) per ambienti multi-dominio più complessi

7. Conclusion (Conclusioni)

L'esercizio ha permesso di implementare correttamente una segregazione dei privilegi basata su gruppi in un ambiente Active Directory, verificando ogni singolo controllo pianificato attraverso strumenti nativi di Windows Server. Tutti i test di conformità hanno dato esito positivo, confermando che l'architettura dei permessi rispetta il principio del minimo privilegio e fornisce una base solida di sicurezza organizzativa, ulteriormente rafforzata dalle restrizioni intrinseche di sicurezza di un Domain Controller.

Appendice A

#	Fase	Comando
1	Verifica privilegi amministrativi	whoami /groups findstr "Administrators"
2	Verifica appartenenza al dominio	systeminfo findstr /B /C:"Domain"
3	Creazione gruppo Marketing	New-ADGroup -Name "G_MarketingTeam" -GroupScope Global -GroupCategory Security -Path "CN=Users,DC=Epicode,DC=local" -Description "Gruppo utenti reparto Marketing"
4	Creazione gruppo Sviluppatori	New-ADGroup -Name "G_Sviluppatori" -GroupScope Global -GroupCategory Security -Path "CN=Users,DC=Epicode,DC=local" -Description "Gruppo sviluppatori software"
5	Creazione cartella Marketing	New-Item -Path "C:\Condivise\Marketing" -ItemType Directory
6	Creazione cartella Sviluppo	New-Item -Path "C:\Condivise\Sviluppo" -ItemType Directory
7	Permessi NTFS su Marketing	icacls "C:\Condivise\Marketing" /inheritance:r /grant "Epicode\G_MarketingTeam:(OI)(CI)M" /grant "Epicode\Domain Admins:(OI)(CI)F"
8	Permessi NTFS su Sviluppo	icacls "C:\Condivise\Sviluppo" /inheritance:r /grant "Epicode\G_Sviluppatori:(OI)(CI)M" /grant "Epicode\Domain Admins:(OI)(CI)F"
9	Creazione cartella ToolSviluppo	New-Item -Path "C:\Program Files\ToolSviluppo" -ItemType Directory
10	Permesso Read&Execute a Sviluppatori	icacls "C:\Program Files\ToolSviluppo" /inheritance:r /grant "Epicode\G_Sviluppatori:(OI)(CI)RX" /grant "Epicode\Domain Admins:(OI)(CI)F"
11	Deny esplicito a Marketing	icacls "C:\Program Files\ToolSviluppo" /deny "Epicode\G_MarketingTeam:(OI)(CI)RX"
12	Aggiunta Sviluppatori a RDP	Add-ADGroupMember -Identity "Remote Desktop Users" -Members "G_Sviluppatori"
13	Creazione utente test Marketing	New-ADUser -Name "Test Marketing" -SamAccountName "TestMarketing" -AccountPassword (ConvertTo-SecureString "Password123!" -AsPlainText -Force) -Enabled \$true -ChangePasswordAtLogon \$false
14	Creazione utente test Sviluppo	New-ADUser -Name "Test Sviluppo" -SamAccountName "TestSviluppo" -AccountPassword (ConvertTo-SecureString "Password123!" -AsPlainText -Force) -Enabled \$true -ChangePasswordAtLogon \$false
15	Aggiunta TestMarketing al gruppo	Add-ADGroupMember -Identity "G_MarketingTeam" -Members "TestMarketing"
16	Aggiunta TestSviluppo al gruppo	Add-ADGroupMember -Identity "G_Sviluppatori" -Members "TestSviluppo"
17	Verifica gruppi creati	Get-ADGroup -Filter 'Name -like "G_*"' Select-Object Name, GroupCategory, GroupScope
18	Verifica membri Marketing	Get-ADGroupMember -Identity "G_MarketingTeam" Select-Object Name
19	Verifica membri Sviluppatori	Get-ADGroupMember -Identity "G_Sviluppatori" Select-Object Name
20	Verifica membri RDP	Get-ADGroupMember -Identity "Remote Desktop Users" Select-Object Name
21	Verifica permessi Marketing	icacls "C:\Condivise\Marketing"
22	Verifica permessi Sviluppo	icacls "C:\Condivise\Sviluppo"
23	Verifica permessi ToolSviluppo	icacls "C:\Program Files\ToolSviluppo"
24	Verifica assenza privilegi admin	Get-ADGroupMember -Identity "Domain Admins" Select-Object Name

